SECURITY AWARENESS TRAINING

# Phishing Awareness

How attackers trick people, and how to spot the trick before it works.

UNDERSTANDING PHISHING

# What is phishing?

A fake message that pretends to come from someone you trust, designed to steal passwords, money or data, or to install malware.

### Email

The classic. Fake invoices, shared files and account alerts.

### Text message

Called smishing. Delivery notices and urgent links.

### Phone call

Called vishing. A caller posing as IT, a bank or a manager.

### QR code

Called quishing. A code on a poster or email that leads to a fake login page.

UNDERSTANDING PHISHING

# Why it works

Phishing does not break software. It exploits four very human reactions.

## Urgency

"Act now or lose access." Time pressure stops us from thinking.

## Authority

Messages that look like they come from a boss, IT or a bank.

## Curiosity

"See who viewed your profile." We want to know what it says.

## Fear

Warnings about a payment problem, a suspended account or a legal issue.

UNDERSTANDING PHISHING

# How an attack unfolds

**1**

### Lure

A message arrives that looks routine and believable.

**2**

### Hook

It creates urgency or curiosity so you act before checking.

**3**

### Harvest

You enter a password, approve a payment or open a file.

**4**

### Exploit

The attacker uses your access for fraud or to reach colleagues.

Stopping at step 2 is the goal. Every extra moment of checking breaks the chain.

SPOTTING PHISHING

# Red flag: check the sender address

The name shown is free to set to anything. The address is what matters.

- Domains that add extra words, such as "helpdesk" or "secure"
- Letters swapped for look-alikes, such as "rn" for "m"
- Free mail accounts for an official-sounding sender

From: **IT Support**

<it-support@acme-helpdesk-verify.net>

Subject: Mailbox will be suspended today

**Red flag: the domain is not acme.com, and the subject creates pressure.**

SPOTTING PHISHING

# Red flag: links that lie

**What the link text says**

www.paypal.com/login

**Where it actually goes**

paypa1-secure-login.com/verify

- Hover over a link, or press and hold on a phone, to see the real destination first.
- Type the site address yourself, or use a saved bookmark, instead of following a link.
- Be wary of shortened links and QR codes you did not expect.

SPOTTING PHISHING

# Red flags inside the message

### Pressure

"Act within 24 hours or your account will be closed." Real deadlines are rare and can be verified.

### Unexpected attachments

An invoice you were not expecting, or a file that ends in .zip, .html or .iso. Do not open it until you have verified it.

### Requests for secrets

Anyone asking for your password, PIN or one-time code is attempting phishing. No legitimate team needs these.

Any one of these is a reason to pause. Two or more together is a strong signal to report.

SPOTTING PHISHING

# The spot-the-phish checklist

| Check | Warning sign |
| --- | --- |
| Sender | Address uses an unfamiliar or look-alike domain |
| Links | Destination differs from the text, or is not the official site |
| Timing | Demands action within minutes or hours |
| Requests | Asks for a password, PIN, one-time code or gift cards |
| Attachments | Unexpected file, especially compressed or macro-enabled |
| Greeting | Generic ("Dear user") or oddly worded and inconsistent |

SPOTTING PHISHING

# Calls and texts are phishing too

## On the phone

A caller claims to be IT, a bank or a manager, and presses for quick action or a code. Hang up, then call back on a number you already know.

## By text

A parcel, toll or account alert with a link. Open the official app or type the address yourself instead of tapping the link.

Rule to remember: legitimate staff will never ask you to read out a one-time code.

QUICK CHECK

# Phish or legitimate?

**1**

Your manager emails asking you to buy gift cards today and send the codes back.

**2**

A text says a parcel is held and asks you to pay a small fee through a link.

**3**

A colleague you work with shares a document link, sent from their usual address, as expected this week.

Discuss your answers before revealing them. Think about what would make each one safe or unsafe.

RESPONDING AND REPORTING

# If you think you clicked

Act quickly. Speed matters more than being embarrassed.

1

### Disconnect

Turn off Wi-Fi or unplug the network cable if you entered anything.

2

### Change passwords

From a device you trust, change the affected passwords first.

3

### Tell IT

Report it right away, even if you feel silly. Early reports limit damage.

4

### Watch

Check your accounts for unfamiliar sign-ins, and enable multi-factor authentication.

RESPONDING AND REPORTING

# Report it, then verify

## Report suspicious messages

Use the report button in your email client, or forward the message to the security team. Do not reply, and do not click anything inside it.

Reporting a phish protects your colleagues too.

## Verify through another channel

If a request looks real but unusual, confirm it by phone or in person using contact details you already trust, not those in the message.

KEY TAKEAWAYS

# Pause, check, then act.

- Urgency and secrecy are warning signs, not reasons to hurry.
- Check the real sender address and the real link destination.
- Never share passwords, PINs or one-time codes.
- Verify unusual requests through a channel you already trust.
- Report suspicious messages, and report quickly if you clicked.